

PROJECT CHARTER

Document Introduction

This document constitutes the official Project Charter for **BindKey**. It formally defines the scope, objectives, and execution framework of our hardware cybersecurity solution, aligning the team's vision with stakeholder expectations.

It details the critical flaws in current USB storage that motivated BindKey's creation specifically regarding secure collaboration and outlines our core Use Cases. Additionally, this charter establishes the High-Level Requirements, technical constraints, success criteria, team responsibilities, and risk mitigation strategies.

Ultimately, this document serves as the foundational agreement for all phases of design, development, and validation of the BindKey ecosystem.



Project Title: BindKey

Project Sponsor: Frédéric Paillart **Date Prepared:** 30/09/2025

Project Manager: William Iniziato **Project Customer:** Frédéric Paillart

Project Team:

William Iniziato
Pierre-Louis Lopez
Marwa Addouh
Jassime Zaieter
Jean-Baptiste Mattei

PROJECT CHARTER

Project Purpose or Justification, Context:

Data transfer through USB drives and external storage devices remains a standard operational practice, yet current solutions exhibit critical security vulnerabilities and operational limitations.

Firstly, most conventional drives lack robust authentication, relying on weak, shared PIN codes or proprietary software that can be bypassed if the host machine is compromised.

Once physical access is obtained, data can be copied or altered without leaving an audit trail, and standard devices remain highly susceptible to malware injection.

Secondly, the few existing highly secure drives act as isolated data silos, hindering enterprise teamwork.

Currently, sharing secure data requires compromising security protocols—such as sharing PIN codes, which destroys traceability—or reverting to cloud transfers, which negates the security benefits of offline, air-gapped storage.

Organizations are forced to choose between strict security and effective collaboration.

Consequently, there is a critical demand for a secure, hardware-enforced architecture that bridges this gap.

A solution is required that guarantees absolute confidentiality and cryptographic integrity, while also providing a secure, Zero-Knowledge mechanism for teams to delegate access and collaborate effectively without exposing sensitive keys.

Project Description:

BindKey is a secure USB proxy positioned between a computer (or server) and an external storage device. It encrypts and seals data during transfer, then decrypts it only for users possessing the required cryptographic access rights to the volume.

The system provides proof of data integrity and authenticity, ensuring that any modification outside BindKey makes the content unreadable.

It relies on biometric authentication and cryptographic tokens, combining security, confidentiality, and trust, without depending on a cloud infrastructure.

The solution is completed by a Desktop Management Software and a centralized server to manage access delegation and user administration. This ecosystem acts strictly as a control interface to orchestrate secure collaboration, while all sensitive keys and cryptographic operations remain isolated within the hardware.

PROJECT CHARTER

Use Case:

Secure Data Transfer & Integrity

Guarantee that sensitive files exchanged between entities remain authentic and unmodified. Any alteration made outside the BindKey environment immediately renders the data unreadable, ensuring end-to-end trust.

Confidential Local Storage

Provide individuals and teams with secure, biometric-enforced access to highly sensitive data, functioning entirely without cloud dependency or network exposure.

Digital Evidence Protection (Forensics & Legal)

Securely transfer forensic, legal, or investigative data while establishing and preserving cryptographic proof of its integrity, authenticity, and chain of custody.

Secure Collaboration & Access Delegation

Allow data owners to securely create encrypted volumes on standard drives and grant specific access rights (e.g., read-only) to authorized colleagues. Cryptographic keys are safely synchronized via the server, enabling colleagues to decrypt the shared volume using their own BindKey and biometrics.

Delegated Administration & Enrollment

Allow high-level administrators to grant localized "Enroller" privileges (e.g., to departmental team leaders). This enables secure, decentralized onboarding of new users (biometric capture, key provisioning) without exposing system-wide administrative controls.

Lifecycle Management & Device Reassignment

Enable administrators to manage the full hardware lifecycle. If a device is lost, it can be instantly revoked via a blocking token. Upon validating a Recovery Code, a user's previous encryption keys can be securely restored to a new BindKey. Alternatively, devices can be securely wiped and reassigned to new users, maintaining strict isolation from previous data.

Secure Firmware Lifecycle

Allow administrators to deploy cryptographically signed security patches to the BindKey hardware. This ensures the system remains resilient against emerging threats over time without ever exposing stored keys or biometric templates.

Audit Logs & Regulatory Compliance

Record critical administrative actions, key restorations, and access delegations in a centralized, tamper-evident server log. This provides the necessary traceability for security audits and strict regulatory compliance.

Secure Air-Gapped Maintenance (OT & Industrial)

Securely transport software updates and maintenance payloads to isolated, air-gapped systems (e.g., ships, factories, critical infrastructure). The device acts as a trusted proxy, guaranteeing the authenticity of the data and preventing malware injection into critical networks.

PROJECT CHARTER

High-Level Requirements:

1. Core Cryptographic & Security Operations

- **Data Encryption & Decryption:** The system must symmetrically encrypt all data written to the external storage device and decrypt it only for users holding the appropriate access rights and successfully authenticated.
- **Integrity Verification:** The system must detect any unauthorized modification of data performed outside the BindKey environment. Altered files must fail integrity checks and remain unreadable.
- **Data Sealing:** The system must securely seal (cryptographically sign and encrypt) files during transfer to guarantee authenticity and non-repudiation.

2. Authentication & Access Control

- **Biometric Authentication:** The system must authenticate the user locally via hardware-based biometric verification (fingerprint) before granting access to cryptographic operations.
- **Tamper Detection & Lockout:** The system must detect brute-force attacks or repeated failed authentication attempts and enforce a strict lockout threshold to protect stored secrets.
- **Role-Based Software Access:** The Desktop Management Software must dynamically detect the privilege level (User, Enroller, Admin) of the connected BindKey and expose only the corresponding features.

3. Device & Lifecycle Management

- **Device Binding:** Each BindKey device must be securely bound to a specific user profile (identity and cryptographic keys).
- **Administrator Management & Reassignment:** The system must allow authorized administrators to securely wipe, reset, or reassign a device to a new user while ensuring absolute isolation from previously stored data.
- **Secure Communication:** Communication between the software/device and the remote server (e.g., during enrollment, sharing, or recovery) must be strongly encrypted and must never expose raw secrets or biometric data over the network.

4. Operational & System Constraints

- **Offline Operation:** The device must be fully autonomous and functional offline for all standard encryption, decryption, and authentication operations.
- **Transparent Proxy Behavior:** The device must act as a transparent proxy, appearing as a standard mass storage drive to the host operating system without requiring custom drivers.

Constraints:

PROJECT CHARTER

1. Hardware & Physical Constraints

- **Low-Power/Embedded Profile:** The system must run efficiently on a low-power microcontroller or System-on-Chip (SoC) with inherently limited storage and processing capacity.
- **Power Delivery:** The device must operate exclusively using standard USB power delivery, requiring no external power supply or internal battery.
- **Storage Architecture:** The device acts strictly as a secure "proxy" and must not host user payload data locally. It solely acts as an intermediary between the host and the external mass storage.

2. Security & Compliance Constraints

- **Zero-Knowledge Hardware:** Biometric templates and master encryption keys must never leave the device hardware in plain text under any circumstances.
- **Cryptographic Standards:** All cryptographic operations must adhere to recognized industry standards (e.g., AES-GCM for payload, ECC for signatures/key exchange, TLS 1.2+ for server communication).
- **GDPR & Privacy (Zero-Leak Policy):** To comply with privacy regulations, sensitive biometric data must remain confined to the hardware's secure enclave (or dedicated flash sector). No plain-text exports or network transmissions of this data are permitted.

3. Performance & Protocol Constraints

- **Transfer Overhead:** The combined overhead of on-the-fly encryption/decryption, biometric checks, and USB protocol management must be optimized to prevent critical bottlenecks during data transfers (minimizing latency, especially on read operations).
- **USB Mass Storage Compliance:** The device firmware must strictly adhere to the USB Mass Storage Class specifications. The microcontroller must manually proxy and manage the USB stack and SCSI command set.

4. Development & Time Constraints

- **Language & Safety:** The software and core logic must be implemented primarily in Rust, leveraging its memory safety, concurrency models, and strong type guarantees to prevent common vulnerabilities.
- **Prototyping Path:** Initial hardware prototyping and proof-of-concept will utilize an ESP32 architecture, with the architecture designed to allow future migration to a custom embedded SoC.
- **Schedule Constraint:** The entire development, integration, and testing lifecycle must be completed within the academic project timeline (September–June).

PROJECT CHARTER

The 5 High-Level Risks (perform the risk matrix to identify the 5 highest risks) :

1. Personal Data Breach (GDPR Compliance Failure)

Description: A flaw in the hardware architecture or software protocol leads to the extraction of plain-text biometric templates or user identities.

Impact: Severe legal penalties, total loss of user trust, and project failure.

Mitigation: Enforce a strict Zero-Knowledge architecture where biometrics never leave the secure element.

2. Compromised Firmware (Supply Chain or OTA Update Attack)

Description: An attacker flashes malicious firmware during manufacturing or intercepts an Over-The-Air (OTA) update to inject a backdoor.

Impact: The device could secretly log encryption keys or bypass biometric checks.

Mitigation: Implement strict cryptographic signature verification for all firmware updates (Secure Boot).

3. Compromised Server Database

Description: A remote attack breaches the centralized management server where user identities, public keys, and wrapped volume keys are stored.

Impact: An attacker could attempt to map the organizational structure or retrieve wrapped keys to attack them offline.

Mitigation: Store only encrypted or wrapped keys on the server. Ensure the server has zero knowledge of the actual volume decryption keys.

4. Privilege Escalation on Admin Workstation

Description: Malware or an attacker compromises the PC running the Desktop Management Software.

Impact: The attacker could attempt to issue rogue administrative commands, such as unauthorized device reassignment or user enrollment.

Mitigation: All critical administrative commands must require physical presence and biometric validation on the BindKey device itself, preventing remote software-only attacks.

5. Side-Channel Attacks or Physical Tampering

Description: An attacker gaining physical possession of the device uses advanced techniques (power analysis, timing attacks, or decapping the chip) to extract the master keys.

Impact: Total compromise of the data stored on the associated external drive.

Mitigation: Utilize secure elements and ensure cryptographic libraries are resistant to timing attacks through constant-time algorithms.

PROJECT CHARTER

Project Objectives	Success Criteria	Person Approving
--------------------	------------------	------------------

Scope:

- Complete realization of a secure ecosystem: a physical USB proxy (Hardware + Rust Firmware), a Desktop Management Software, and a central Admin Server.	- 100% of critical requirements are met (Encryption, Integrity, Local Auth, Offline Mode, Device Recovery) and validated through testing.	Frédéric Paillart
---	---	-------------------

Time:

- Adhere to the academic project schedule, including S7 and S8 presentations and regular reporting.	- 100% of deadlines respected - A working prototype is presented in December, the final prototype in February, and the complete final product with full documentation in June.	Frédéric Paillart Jessica Giacobi
---	---	--------------------------------------

Cost:

- Manage the procurement of electronic components, PCBs, and shipping within the allocated academic constraints.	- The total expenses remain strictly within the validated budget (PCB: 160 €, Shipping: 57 €, plus component costs).	Jessica Giacobi
--	--	-----------------

Other:

- Prototype: Demonstrate on-the-fly encryption/decryption with authentication (biometric or simulated).	- The prototype is fully functional during the S7 presentation. AES-GCM encryption and data integrity verification are successfully implemented and demonstrated.	Project Team
Documentation: Provide complete source code and deployment documentation.	- The Git repository is fully complete, up to date, and includes a clear README.md explaining compilation, flashing, and usage procedures.	Project Team

PROJECT CHARTER

Summary Milestones (must appear on your planning too)	Due Date (not confirmed)
Project launch	17/09/25
Project launch / Option	18/09/25
Working Prototype with basic features	19/12/2025
Validation / securing of the framework	19/12/2025
Gantt	First 02/2025 Final 30/05/2026 23h59
RACI matrix	First 02/025 Final 30/05/2026 23h59
Risk matrix	First 02/2025 Final 30/05/2026 23h59
Project Charter	02/2026
Requirements	02/2026
Finalizing the Prototype	02/2026
Recipe S7	05/02/2026
Jury S7	06/02/2026
Hardware Revision	Mid-March 2026
Feature Complete	End-April 2026
Final Assembly	Mid-May 2026
WBS	30/05/2026 23h59
OBS	30/05/2026 23h59
Technical documentation	30/05/2026 23h59

PROJECT CHARTER

Jury S8	01/06/2026
Recipe S8	04/06/2026
Cowork presentation	05/06/2026

Team Organization:

Name	Position	Role	Contact Information	Requirements
William Iniziato	Project & Team Manager	Team Lead & Microcontroller Lead	william.iniziato@isen.yncrea.fr	- Manages the project and tasks. - Submits all weekly reports. - Develops the core microcontroller logic for the USB Proxy
Jassime Zaieter & Marwa Addouh	Project Members	Backend & Server Team	jassime.zaieter@isen.yncrea.fr marwa.addouh@isen.yncrea.fr	- Develop and deploy the central Rust server and manage the PostgreSQL database. - Implement the secure API for user synchronization and the key recovery mechanism.
Pierre-Louis Lopez	Project Member	Biometric Lead	pierre-louis.lopez@isen.yncrea.fr	- Selects and integrates the biometric sensor hardware. - Manages the hardware-level fingerprint authentication process.
Jean-Baptiste Mattei	Project Member	Software Lead	jean-baptiste.mattei@isen.yncrea.fr	- Develops the desktop BindKey Management App. - Implements the communication stack between the software, the backend, and the hardware device.

PROJECT CHARTER

Estimated Budget:

217 Euros

Stakeholder(s)	Role
Frédéric Paillart	Project Sponsor / Customer / Tutor / Approver
Jessica Giacobi	Project Supervisor / Approver
Project Team	Execution, Development & Delivery
Target End Users	Consulted Parties

Approvals:

Iniziato

Project Manager Signature

William Iniziato

Project Manager Name

18/12/2025

Date

Sponsor or Originator Signature

Sponsor or Originator Name

Date